

09.03 Firewall – 09.04 IPS e IDS

Reti di Calcolatori – Sicurezza

Firewall

- Un firewall costituisce una barriera attraverso la quale deve passare il traffico di rete.
 - La politica di sicurezza del firewall stabilisce quale traffico è autorizzato a passare in ciascuna direzione.
 - Un firewall può essere progettato per operare come filtro a livello di rete (pacchetti IP) oppure a livelli superiori per altri protocolli.
 - Il firewall rappresenta una linea di difesa che isola i sistemi interni dalle reti esterne.
-

Caratteristiche del Firewall

- **Controllo dei servizi:** determina quali servizi Internet possono essere utilizzati in ingresso o in uscita.
 - **Controllo della direzione:** determina la direzione in cui determinate richieste di servizio possono essere avviate e consentite attraverso il firewall.
 - **Controllo degli utenti:** regola l'accesso ai servizi in base all'utente che tenta di utilizzarli.
 - **Controllo del comportamento:** controlla il modo in cui vengono utilizzati specifici servizi.
-

Funzioni del Firewall

- Definisce un punto di controllo unico che impedisce agli utenti non autorizzati di accedere alla rete protetta, blocca servizi vulnerabili e protegge da attacchi di spoofing IP e routing.
 - Fornisce un punto centralizzato per il monitoraggio degli eventi di sicurezza, consentendo audit e sistemi di allarme.
 - Costituisce una piattaforma utile anche per alcune funzioni Internet non strettamente legate alla sicurezza.
-

Limitazioni del Firewall

- Non può proteggere da attacchi studiati appositamente per aggirarlo.
 - I sistemi interni potrebbero avere connessioni dirette a un ISP, bypassando il firewall.
 - Non garantisce una protezione completa contro minacce interne, come dipendenti malevoli o inconsapevoli.
 - Una rete LAN wireless non adeguatamente protetta potrebbe essere accessibile dall'esterno.
-

Tipologie di Firewall

1. Packet Filtering Firewall

Applica un insieme di regole a ogni pacchetto IP in ingresso e in uscita, decidendo se inoltrarlo o scartarlo.

2. Stateful Inspection Firewall

Tiene traccia dello stato delle connessioni di rete (ad esempio flussi TCP) e consente solo i pacchetti appartenenti a connessioni attive e legittime.

3. Application-Level Gateway (Proxy Applicativo)

Agisce come intermediario per il traffico a livello applicativo. L'utente si connette al gateway, che verifica l'identità e inoltra i dati verso l'host remoto.

4. Circuit-Level Gateway

Non permette una connessione TCP diretta end-to-end, ma crea due connessioni separate: una con l'host interno e una con quello esterno.

Configurazione del Firewall

DMZ (Demilitarized Zone)

- È una porzione di rete situata tra la rete protetta e Internet.
- Serve a fornire un livello aggiuntivo di sicurezza ai server che offrono servizi pubblici come:
 - HTTP / HTTPS
 - FTP
 - DNS
 - SMTP
- I server nella DMZ:
 - sono accessibili dalla rete interna in modo sicuro;
 - sono raggiungibili dall'esterno con restrizioni appropriate.

IDS e IPS

Il processo di intrusione in un sistema comprende diverse fasi:

1. Identificazione del bersaglio.
2. Ricognizione e raccolta di informazioni.
3. Ottenimento dell'accesso al sistema.
4. Utilizzo improprio delle risorse del sistema.

IDS (Intrusion Detection System)

L'Intrusion Detection è l'attività di individuazione di comportamenti inappropriati, errati o anomali.

Un IDS viene utilizzato per verificare se una rete o un server hanno subito intrusioni non autorizzate.

IPS (Intrusion Prevention System)

Un IPS agisce attivamente:

- scarta pacchetti contenenti dati non autorizzati;
- interrompe connessioni sospette.

La tecnologia IPS può essere vista come un'estensione dell'IDS.

Posizionamento dell'IDS

- L'IDS è uno strumento che fornisce visibilità sul traffico di rete.
 - Se posizionato tra router di frontiera e firewall, consente di rilevare un attaccante prima che raggiunga la zona protetta.
 - Se installato all'esterno del firewall, permette di osservare l'intera gamma di attacchi diretti alla rete.
-

Vantaggi e Svantaggi dell'IDS

L'IDS opera in **modalità promiscua**, ascoltando tutto il traffico senza essere direttamente inserito nel flusso di rete.

Vantaggi

- Nessun impatto sulle prestazioni della rete.
- Nessuna latenza o jitter aggiuntivi.
- Nessun effetto sulla rete in caso di guasto del sensore.
- Nessun impatto anche in caso di sovraccarico del sensore.

Svantaggi

- Si limita a segnalare l'attacco, senza bloccarlo.
 - Richiede una corretta configurazione.
 - Necessita di una politica di sicurezza ben definita.
 - Le reti vulnerabili possono essere soggette a tecniche di evasione.
-

Ulteriori vantaggi e svantaggi dell'IDS

L'IDS:

- registra gli incidenti in un database;
- genera avvisi per l'amministratore di rete;
- aiuta a identificare problemi nelle politiche di sicurezza;
- documenta le minacce esistenti;
- scoraggia violazioni interne.

Problema principale

L'IDS produce molti **falsi positivi**, classificando talvolta traffico legittimo come malevolo.

Svantaggi dell'IPS

Rispetto all'IDS:

- è connesso direttamente alla rete (**inline**) e può influenzarne il traffico;
 - un sovraccarico del sensore può degradare le prestazioni;
 - richiede una politica di sicurezza accurata;
 - può introdurre latenza e jitter.
-

Considerazioni

Gli attacchi possono verificarsi molto rapidamente e concludersi prima che un amministratore riesca a intervenire.

L'IPS può caricare file di firme (signature), analoghi alle definizioni degli antivirus, per individuare modelli di attacco.

In base alle politiche di sicurezza configurate, l'IPS può:

- bloccare automaticamente gli attacchi;
 - generare notifiche sugli eventi rilevati.
-

IDS e IPS insieme

Un IPS può reagire a una minaccia riconfigurando altri dispositivi di sicurezza, come firewall o router, per bloccare l'attacco.

Poiché IDS e IPS sono collocati in punti diversi della rete, possono essere utilizzati contemporaneamente:

- **IPS al perimetro della rete**
 - blocca worm, virus e attacchi zero-day;
 - con una corretta configurazione può fermare anche minacce molto recenti.
- **IDS all'interno del firewall**
 - monitora le attività interne;
 - protegge dalle minacce provenienti dagli utenti interni;
 - fornisce una maggiore visibilità sugli eventi di sicurezza presenti e passati.